ISO/IEC 27001:2022 — COURSE ASSESSMENT

10 Multiple Choice Questions & Answer Key

1. What does ISO/IEC 27001:2022 primarily specify?

A) Software development guidelines
B) Requirements for an ISMS
C) Personal data protection rights
D) Network cable standards

Answer: B) Requirements for an ISMS

2. How many controls are listed in Annex A of ISO/IEC 27001:2022?

A) 114 controls
B) 93 controls
C) 150 controls
D) 82 controls

Answer: B) 93 controls

3. Annex A controls in ISO/IEC 27001:2022 are categorized into how many themes?

A) 4 themes
B) 14 themes
C) 10 themes
D) 6 themes

Answer: A) 4 themes

4. Which of the following is NOT one of the four main themes in Annex A (2022 edition)?

A) Organizational controls
B) Financial controls
C) Physical controls
D) Technological controls

Answer: B) Financial controls

5. What does "ISMS" stand for in the context of ISO 27001?

A) Information Security Management System
B) Integrated System Management System
C) Internet Security and Monitoring System
D) Information Storage Model standard

Answer: A) Information Security Management System

6. Which clause of ISO/IEC 27001 focuses on "Operation" and risk treatment execution?

A) Clause 4
B) Clause 6
C) Clause 8
D) Clause 10

Answer: C) Clause 8

7. What document must an organization produce to declare which Annex A controls apply to their ISMS?

A) Statement of Applicability (SoA)
B) Service Level Agreement (SLA)
C) Non-Disclosure Agreement (NDA)
D) Business Impact Analysis (BIA)

Answer: A) Statement of Applicability (SoA)

8. Which methodology is typically referenced for continuous improvement in ISO standards?

A) Agile / Scrum
B) Plan-Do-Check-Act (PDCA)
C) Waterfall
D) Six Sigma DMAIC

Answer: B) Plan-Do-Check-Act (PDCA)

9. Under ISO/IEC 27001:2022, which title refers to the theme containing human resources security controls?

A) Organizational controls
B) People controls
C) Physical controls
D) Technological controls

Answer: B) People controls

10. What is the primary purpose of an internal ISMS audit (Clause 9.2)?

A) To penalize non-compliant employees
B) To verify conformance with standard requirements
C) To replace external certification audits
D) To design network architecture

Answer: B) To verify conformance with standard requirements